

Part 2 of 2

How to Ensure E-mail Security

In the first part, we talked about how the e-mail system works and issues in its security including threats such as loss of confidentiality and integrity, disclosure of sensitive information, exposure of systems to DoS attacks, exposure of individuals to denial of service attacks, etc. In this part, we will discuss challenges related to e-mail authentication and spam, e-mailing the right people, preparing backups, avoiding fraudulent e-mails and malware, etc

RAKESH SHUKLA

E-mail authentication has become a big problem and many methods are being incorporated by e-mail servers across the world to overcome this problem. There are many techniques which have been used these days for managing challenges related to e-mail authentication and spam. We will discuss three main techniques here:

1. DomainKeys identified mail (DKIM). This is a method for e-mail authentication that allows a person to verify the e-mail received in which the e-mail claims to have arrived from a particular domain. The need for this type of authentication arises because spam often has forged headers.

For example, a message claims in its 'From:' header to be from `impersonator@192.9.200.251`. But the e-mail is not actually from the 192.9.200.251 domain. In this scenario, the recipient can raise a complaint to the system administrator for 192.9.200.251 domain, but even then there will be no solution for the same. It also becomes difficult for recipients to establish whether such domains are good or bad. And system administrators may have to deal with complaints about spam that appears to have originated from their systems, but did not.

DKIM is one such solution which uses public-key cryptography to allow the sender to electronically sign legitimate e-mails in a way that can be verified by recipients. Prominent e-mail service providers implementing

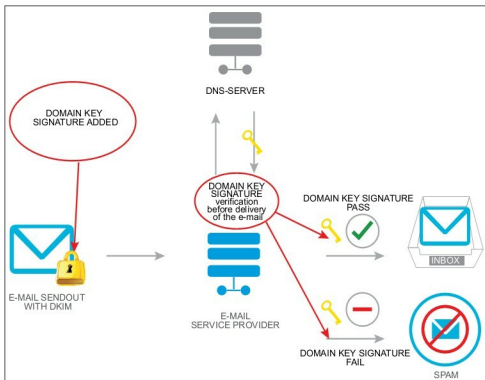


Fig. 7. DKIM flow

DKIM include Yahoo and Gmail. Any mail originating from these domains carries a DKIM signature, and if the recipient knows this, he can discard mail that has not been signed, or that has an invalid signature.

DKIM also guards against tampering with mail, offering almost end-to-end integrity from a signing to a verifying mail transfer agent (MTA). In most cases, the signing MTA acts on behalf of the sender by inserting a DKIM-signature header, and the verifying MTA on behalf of the receiver, validating the signature by retrieving a sender's public key through the DNS. DKIM adds a header named 'DKIM-Signature' that

contains a digital signature of the contents (headers and body) of the mail message. The default parameters for the authentication mechanism use SHA-256 as the cryptographic hash and RSA as the public key encryption scheme, and encode the encrypted hash using Base64.

The receiving simple mail transfer protocol (SMTP) server then uses the name of the domain from which the mail originated, the string `_domain-key` and a selector from the header to perform a DNS lookup. The returned data includes the domain's public key. The receiver can then decrypt the hash value in the header field and at the same time recalculate the hash value